INFORMATION SECURITY LOGGING GUIDELINE

Information Security Logging Guideline	
Framework type	Information security guideline
Guidelines owner	Louis Buteau-Vaillancourt, Director, Information Security Protection and Analysis
Guidelines objectives	Provide developers, integrators, designers, and architects with aggregated guidance on designing and implementing information security logging mechanisms These guidelines support the application of the Security Monitoring and Analysis Standard.
Effective date	2025-03-10
Frequency of review	Once (1) per two years or following major changes

Confidentiality notice

The information contained in this document is intended for use by the iA Financial Group only.

Subject to the approval of a duly authorized representative of iA Financial Group, any reproduction of this document, or its distribution outside of the authorized group of users, is prohibited.

Table of contents

1. Introduction 3
   1.1. SCOPE 3
   1.2. CONTEXT 3
2. Information Security Logging Guideline 4
   2.1. EVENT DATA SOURCES 4
   2.2. EVENTS TO LOG 5
   2.3. EVENT ATTRIBUTES 7
      2.3.1. Event inclusions 7
      2.3.2. Event exclusions 9
      2.3.3. Event format 9
      2.3.4. Event collection 9
      2.3.5. Storage 10
      2.3.6. Verification 10
   2.4. DEPLOYMENT AND OPERATION 11
      2.4.1. Release 11
      2.4.2. Operation 11
      2.4.3. Protection 11
   2.5. DISPOSAL OF LOGS 12

Registre des approbations 13

Historique des révisions 13

Appendix A. References 14

1. Introduction

1.1. Scope

The *Information Security Logging Guideline* applies to iA Financial Group (iAFG) and is specifically intended for its employees, service providers, subcontractors, consultants, and any person whose work is under the responsibility of the Company's management, over whom the Company exercises direct control and who uses the assets of iA Financial Group.

The *Information Security Logging Guideline* supports the application of the *Monitoring and Analysis Security Standard* and details the requirements related to the ***logging*** of information security events. More specifically, it presents the principles, business rules, guidelines, and best practices on the details of the events to be logged.

The detailed procedure to activate logging on a specific IT asset is outside the scope of this document as this vastly differs from system to system and requires the knowledge of the IT asset's administrators.

The *Information Security Logging Guideline* specifically addresses the logging of Information Security events that would typically be consumed by a Security Information and Event Management (SIEM) platform (if the logs are required for security ***monitoring***); it does ***not*** cover the logging requirements for Application Performance Monitoring (APM), Digital Experience Monitoring (DEM) and Network Performance Monitoring and Diagnostics (NPMD).

Note that not all Information Security logs collected will eventually go to a SIEM platform. The SIEM is a monitoring platform, and logs that do not require real-time monitoring will typically be routed and preserved in an alternate vault (in a more cost-efficient manner, and to minimize the performance impacts on the SIEM). The actual ***monitoring*** guidelines, best practices and processes are outside the scope of this document.

The use of "iA Financial Group" or the "Company" in this document refers to iA Financial Corporation Inc. and its subsidiaries.

1.2. Context

Information security event logging supports the continued delivery of operations and improves the security and resilience of critical systems by enabling network visibility.

Logging should be consistent across an organization's IT assets portfolio and use industry standards and best practices where relevant, so the logged event data can be consumed, correlated, analyzed and managed by a wide variety of systems. Common usages for Information Security logs include:

- Identifying information security events that may indicate a security incident
- Improving the probability of detecting malicious behavior through behavior analytics, anomaly detection and proactive hunting (threat hunting)
- Supporting incident response by providing additional asset-specific data

- Monitoring organizational policy compliance
- Establishing baselines (e.g : the “business as usual” process)
- Supporting non-repudiation controls
- Providing additional information about problems and unusual conditions
- Helping defend against vulnerabilities and exploits through attack detection
- Fulfilling the Organization’s legal, regulatory and contractual obligations

In this context, the application of this Information Security Logging Guideline helps to mitigate operational risks such as data and information management, IT operational incidents, logical attacks, software failures or unauthorized actions.

2. Information Security Logging Guideline

2.1. Event Data Sources

Following the last iteration of the Logging NFR SS-SECU-7, security systems as well as cross-functional IT solutions* log sources should be prioritized. Those platforms usually offer a wider coverage than a specific application, facilitate integration to logging and/or monitoring platforms through native connectors, easier log standardization, and are also usually easier to work with (security vendors and/or communities of largely used solutions can provide security monitoring baselines, field-tested security use cases or general guidance and best practices, making the design of security monitoring use cases more straightforward).

Examples of platforms included in this description:

Authentication and authorization:

- Identity and access management systems, authentication servers
- Privileged access and management system (PAM for activation/ deactivation and monitoring of user access with privileged account)
- Domain management systems

Cloud service:

- Cloud environments (Azure, AWS, GCP, Oracle)
- Cloud management and orchestration platforms

Network and perimeter:

- Network firewalls
- Network and host intrusion detection systems (NIDS and HIDS)
- Application firewalls (e.g. filters, guards, XML gateways, database firewalls, web application firewalls (WAFs), web application and API protection (WAAPs))
- Network services as DHCP and DNS services
- Networking assets (switches, routers, Wi-Fi, etc.)
- VPN solutions
- Web proxies used by human and non-human accounts
- Internet-facing services not covered above

Security platforms:

- Vulnerability management systems (e.g.: Kenna)
- Data Loss Prevention (for data discovery, data classification and data handling)
- Antivirus, anti-malware, endpoint protection (EPP) and endpoint detection and response (EDR) platforms
- Emails servers, email protection platforms used by human and non-human accounts

Cross-functional IT platforms:

- Critical systems holding sensitive data likely to be targeted ("crown jewels")
- Database applications (e.g. automatic audit trails, trigger-based actions)
- Asset and service monitoring systems (system or service availability)
- Asset discovery systems
- IT service management system (for change management and validation, incidents, assets classification, CMDB for asset dependency, etc.)
- File, web and printing servers
- Containerization platforms (Kubernetes, etc)
- Infrastructure virtualization
- Event streaming platforms (Kafka, etc)
- Mobile Device Management platforms (MDM)
- Human Resources platforms (Workday)
- Customer relationship management platforms (Salesforce)
- Integration (Mulesoft, Scriptflow, Cinchy)
- Automation systems (Camunda, Content Server, RPA)
- Delivery systems (Azure DevOps, Flagsmith, Humanitec, Backstage)

Application logs, while typically requiring customized integration efforts and involvement from the asset owner (for subject matter knowledge), can usually provide more detailed information, providing complementary and contextual information not available at the infrastructure level, such as:

- Identities
- Roles
- Permissions
- Targets
- Actions
- Outcomes

2.2. Events to Log

Security events from assets that are subject to the Non-Fonctional Requirement NFR SS-SECU-7 should always be logged in a ISO-PROD environments (Production or Acceptation tiers). Additionally and depending on the criticality of the data handled by the asset, logging security events from a "lower" environment tier (i.e. Development) might be required and will be evaluated on a case by case basis.

The nature of the security events will typically vary by system, so the first step from the asset owner point of view should be to review, when available:

- the supplier's recommended security settings and configurations.
- configuration recommendations and benchmarks from the Center for Internet Security (CIS), and other recognized cybersecurity expert communities.

Following are examples of events that are recommended to be logged:

Access control - logs that track access to sensitive resources, including file access, permission changes, and user activity:

- User access to personally identifiable information (PII), such as reading, updating and deleting records containing personal information.
- All actions by users with administrative privileges
- Privileged account access
- Access to payment cardholder data
- Changes to role-based or user-based privileges
- Assigning or deleting system role to user
- Use of systems administrative privileges
- Addition or deletion of users
- Use of data encryption keys
- Assigning users to tokens
- Account password or token initialization or modification

Antivirus/Anti-malware - records of malware detection, removal actions, and system scans

- Native security detections (detection of potential security threats and actions by a security system)

Application security - security-related events generated by applications, such as unauthorized access attempts:

- Input validation failures (e.g. protocol violations, unacceptable encodings, invalid parameter names and values)
- Application and related systems start-ups and shut-downs, and logging initialization (starting, stopping or pausing)
- Potentially malicious usage of "living off the land binaries" (LOLBins), see *(Gov-AU-1, app. C)*
- Output validation failures e.g. database record set mismatch, invalid data encoding
- Data import and export including screen-based reports
- Session management failures
- Native security detections (detection of potential security threats and actions by a security system)

Authentication and authorization - records of login attempts, both successful and failed, including details like user IDs, timestamps, and IP addresses:

- Authentication successes and failures
- Authorization (access control) success and failures
- User session termination (logging-off or timed-out)

Configuration change - Logs that track changes to system and network configurations, including who made the changes and when:

- Modifications to configurations or controls having an impact on security
- Adding or deleting tokens
- Certificate modifications
- Encryption key changes
- Control plane operations on cloud environments

Firewall, intrusion detection/prevention and traffic - records of traffic allowed or blocked by the firewall, logs of network activity

- New network connections
- Network connection failure and success
- Network-based resource calls (HTTP-page or URL resource, API-functions, shares) success or failure (authorization or inexistant resource)
- DNS request and Domain name resolution
- DHCP request (IP release and reallocation)
- Suspicious login location (impossible travel, etc)
- Submission of user-generated content - especially file uploads
- Detection of potential security threats and actions

System event - logs of significant system events, such as startup, shutdown, and system errors

- New discovered asset or service
- Creation and deletion of system-level objects
- lapto object permissions (file, folder)

2.3. Event attributes

2.3.1. Event inclusions

Each log entry needs to include sufficient information for the intended subsequent monitoring and analysis. It could be full content data but is more likely to be an extract or just summary attributes.

The application logs must record "who, what, where and when" (aka *Four W's*) for each event. The properties for these will be different depending on the architecture, class of application and host system/device, but often include the following:

Four W's	Event attributes
Who	• Human or non-human user • Source address (e.g. user's device/machine identifier, user's IP address, RFID) • User identity, if authenticated or otherwise known (e.g. user database table primary key value, username) • Device identifier (MAC address or other unique identifier)

What	• Type of event • Severity of event (e.g. {0=emergency, 1=alert, ..., 7=debug}, {fatal, error, warning, info, debug, trace}) • Security relevant event flag • Description • Action - original intended purpose of the request (e.g. log in, refresh session ID, log out, update profile)
Where	• Indications on where the event occurred • Application identifier (e.g. name and version) • Origin and destination address (e.g. IPv4 or IPv6 address and port number, workstation identity, local device identifier) • Service (e.g. name and protocol) • Geolocation (especially from “sensitive” or “unauthorized” countries, see list of authorized jurisdictions for data transfer for more information) • Window/form/page (e.g. entry point URL and HTTP method for a web application, dialogue box name)
When	• Timestamp (date and time) in a consistent time format, synchronized to an internal and/or authorized time server • Event date and time - the event timestamp may be different to the time of logging (e.g. server logging where the client application is hosted on remote device that is only periodically or intermittently online)
Additional information to consider	• Justification of the action that took place in the event • Secondary time source (e.g. GPS) event date and time • Autonomous System Number (ASN) • Object – the affected component or other object (user account, data resource, file) (e.g. URL, session ID, user account, file) • Command executed • Result status – whether the ACTION aimed at the OBJECT was successful (e.g. success, fail, defer) • Reason – why the status above occurred (e.g. user not authenticated, incorrect credentials) • HTTP Status Code (web applications only) – the status code returned to the user (often 200 or 301) • Request HTTP headers or HTTP User Agent (web applications only) • User type classification (e.g. public, authenticated user, external user, authorized penetration tester (see "Data to Exclude" section below)) • Analytical confidence in the event detection (e.g. low, medium, high or a numeric value) • Responses seen by the user and/or taken by the application (e.g. status code, custom text messages, session termination, response time, administrator alerts) • Extended details (e.g. stack trace, system error messages, debug information, HTTP request body, HTTP response headers and body) • Internal classifications (e.g. responsibility, compliance references)

	• External classifications (e.g. NIST Security Content Automation Protocol (SCAP), Mitre Common Attack Pattern Enumeration and Classification (CAPEC))

2.3.2. Event exclusions

The following should not usually be recorded directly into the security logs. If recorded, it should be removed, masked, sanitized, hashed or encrypted, depending on compliance requirement framework & governance teams:

- Data of a higher security classification than the logging system can store.
- Access tokens.
- Sensitive personal data and personally identifiable information (PII) (e.g. health, government identifiers, vulnerable people); for more information read the Data Classification Standard
- Authentication passwords.
- Database connection strings.
- Encryption keys and other master secrets.
- Bank account or payment card holder data.
- Commercially sensitive information.
- Information it is illegal to collect in the relevant jurisdictions.
- Information a user has opted out of collection, or not consented to (e.g. use of do not track, or where consent to collect has expired);
- Session identification values (consider replacing with a hashed value if needed to track session specific events).

2.3.3. Event format

- Care should be given to make sure that the logs are in the most readable format possible.
- Where possible, all data should be formatted as 'key-value-pairs' to allow for easier extraction.
- A structured log format, such as JSON or another industry standard format, where each type of log captures and presents content consistently should be preferred to improve the defenders's ability to search for, filter and correlate logs.
- Timestamps (date and time entry) should follow the ISO8601 format (UTC) and provide up to the millisecond granularity if possible. Coordinated Universal Time (UTC) formatting provides a consistent timestamp experience and eliminates time zones and daylight savings time.
- Whenever possible, systematic log normalization of the events attributes and format will be implemented by the logging platform team at the logging platform level,
    - to make logging data from different sources comparable and more consistent (e.g. common naming convention for origin/destination IP addresses, etc).
    - to reduce data mapping efforts

2.3.4. Event collection

Consider the following;

- Perform input validation on event data from other trust zones to ensure it is in the correct format (and consider alerting and not logging if there is an input validation failure)

- If possible, perform sanitization on all event data to prevent log injection attacks (e.g. carriage return (CR), line feed (LF) and delimiter characters (and optionally to remove sensitive data))
- If writing to databases, read, understand, and apply the SQL injection prevention measures.
- Encode data appropriately for the output format.
- Ensure failures in the logging processes/systems do not prevent the application from otherwise running or allow information leakage.
- Synchronize time across all servers and devices to an authorized time source.
- Ensure that an unaltered version of the collected logs is available to be replayed for future use (specifically when logs are filtered, reduced, normalized, and/or otherwise modified before being sent to a destination like a SIEM)

2.3.5. Storage

Storage of the logs must be in an space other than the system that generates the logs and the choice of the solution is to be chosen by the solutions architect. Logging solutions include, but are not limited to:

- Log Analytics Workspace to be hosted in a sector-specific cloud subscription.
- Azure Storage Account.

The chosen storage solution and/or instance for logs must be declared for further security investigation purposes. See the IS Service Catalog in IS Showcase, under "Monitoring and Analysis", for a link to make that declaration.

2.3.6. Verification

Logging functionality and systems must be included in code review, application testing and security verification processes and must be done before deploying into a production environment:

- Verifying that event logging is enabled, active and working as intended for system components.
- Check events are being classified consistently and the field names, types and lengths are correctly defined to an agreed standard.
- Ensure logging is implemented and enabled during application security, penetration, and performance testing.
- Test that the mechanisms are not susceptible to injection attacks.
- Ensure there are no unwanted side-effects when logging occurs.
- Check the effect on the logging mechanisms when external network connectivity is lost (if this is usually required).
- Ensure logging cannot be used to deplete system resources, for example by filling up disk space or exceeding database transaction log space, leading to denial of service (assess and calculate the necessary disk space required to store the logs, then establish a retention and rotation period accordingly. Note: The logs will be retained at the authorized logging platform based on the regulatory requirements).
- Test the effect of logging failures on the application such as simulated database connectivity loss, lack of file system space, missing write permissions to the file system, and runtime errors in the logging module itself.
- Verify access controls on the event log data.
- Ensure that logs can be accessed and read by the security incident response team (REACT).

- If log data is utilized in any action against users (e.g. blocking access, account lock-out), ensure this cannot be used to cause denial of service (DoS) of other users.

Please refer to the "Security Monitoring and Analysis" standard for more details.

2.4. Deployment and Operation

2.4.1. Release

- Provide security configuration information by documenting the details of the logging mechanisms
- Inform or consult the application, asset or process owner about the information security logging mechanisms.

2.4.2. Operation

Mechanisms must be deployed by information asset owners to detect whether logging has stopped, or that unauthorized access, tampering or deletion of the logs has occurred before they reached the logging platform. The feasibility of an integration into the Application Performance Monitoring (APM) platform should be evaluated with the monitoring and observability team (which is different than the security monitoring, or SIEM team).

Make sure the asset is properly classified (***NFR SS-SECU-10 - Categorize IT software and hardware assets***) in the organizational governance, risk and compliance platform (Hopex).

Note that information security logging is included in the scope of the NFRs ***SS-MAIN-2 Ensure monitoring and compliance with service levels (SLA/OLA)*** and ***SS-RELI-1 Ensure continuity of activities and services***.

Please review the monitoring NFRs and orientations for more details.

2.4.3. Protection

To ensure data integrity, logging facilities and log information must be protected by cryptographic methods from tampering and unauthorized access.

- Ensure that only individuals who have a job-related need can view, access, or modify log files (on a "need-to-know" basis)
- Periodically review the access to view, access, or modify log files
- Document views and usage of log files and regularly reviewing/auditing the resulting records
- Confirm that log files are protected from unauthorized modifications via access control mechanisms, such as virtual or physical segregation, and tamper detection
- Ensure that log files are promptly backed up to an out-of-band, centralized and authorized logging platform (WORM : write-once, read-many)
- Use integrity-verification mechanisms to detect unauthorized changes to event logging configuration and log files that are no longer being written to or are considered closed.

- Consider conducting integrity checks periodically and upon access against the log hashes throughout their retention period.
- If log data is sent over untrusted networks (e.g. for collection, routing elsewhere, analysis or for reporting), use a secure transmission protocol.
- Perform due diligence (regulatory and security) before sending event data to third parties. The Guide is available here: Due Dilligence guide

Note: Accessing, tampering, modifying or deleting logs without proper authorization is considered a severe security incident and mechanisms must be in place to monitor and alert for the tampering (in transit or at rest) and unauthorized access of the logs

Please refer to the "Security Monitoring and Analytics" standard for more details.

2.5. Disposal of logs

Log data, temporary debug logs, and backups/copies/extractions, must not be destroyed before the duration of the required data retention period, and must not be kept beyond this time.

Legal, regulatory, and contractual obligations may impact on these periods. For example, a legal hold procedure which requires a longer retention period for the safekeeping of evidences for a case that might go to court.

Logs that are uploaded to investigation environment or logs that exceeded the legal retention period, should be sanitized following a company-accepted sanitation process

Note: Retention periods are defined in the Log Retention and Disposal requirements of the "Security Monitoring and Analytics" standard

Registre des approbations

Version 1.0	Date
• Louis Buteau-Vaillancourt, Directeur Protection et analyse en sécurité de l'information	2025-02-04
•	

Historique des révisions

Version	Impact	Changements	Date
1.0	Majeur	Publication	2025-03-10

Appendix A. References

Internal references

Non Functional requirements
Orientation : Continuité des opérations des systèmes TI
Orientation : Surveillance, Observabilité & Gestion des événements TI
Standard : Data Classification
Standard : Identity and Access Management Security
Standard : Security Monitoring and Analytics
Guideline : Information Security Due Diligence
List : Liste des juridictions autorisées pour le transfert de données
IT Glossary

External references

(Gov-Joint-1)	Best practices for event logging and threat detection
(Gov-CAN-1)	C-26 (44-1) - LEGISinfo - Parliament of Canada
(Gov-US-1)	SP 800-92 Rev. 1, Cybersecurity Log Management Planning Guide | CSRC (nist.gov)
(Gov-US-2)	SP 800-92, Guide to Computer Security Log Management (nist.gov)
(Gov-US-3)	Guidance for Implementing M-21-31: Improving the Ferderal Government's Investigative and Remediation Capabilities (cisa.gov)
(Gov-US-4)	Text - S.3600 - 117th Congress (2021-2022): Strengthening American Cybersecurity Act of 2022 (Congress.gov)
(Gov-US-5)	M-21-31 (whitehouse.gov)
(Gov-AU-1)	Identifying and Mitigating Living Off the Land Techniques | Cyber.gov.au
(MITRE-1)	MITRE ATT&CK Data Sources – recommended data log sources
(Msft-1)	Normalization and the Advanced Security Information Model (ASIM) - Microsoft
(Splunk-1)	Log Normalization - Overview of the Splunk Common Information Model - Splunk